Monthly Intelligence Dispatch

March 2019

The Group-IB Monthly Threat Intelligence Dispatch (Group-IB MTID) is a monthly newsletter by Group-IB, an international company that specialises in preventing cyberattacks and developing information security products. The dispatch aims to provide information about the latest cyberthreats, criminal groups' attacks, leaks, and malware. The document contains news about arrests, legal action against hacking groups, short-term forecasts, and recommendations to help take timely measures to reduce security risks and ensure protection against cyberthreats. Group-IB MTID is intended for internal use only and its distribution is not permitted.

Key findings

- Group-IB detected the Gustuff Android Trojan. Its victims include clients of 100 international banks, users of 32 cryptocurrency wallets, and customers of major e-commerce businesses.
- The Indian APT DoNot Team (aka APT-C-35) is believed to be behind the LUCKY ELEPHANT credential harvesting cyber-espionage campaign.
- **Microsoft** took control of 99 domains used by the pro-Iranian APT Phosphorus.
- **Group-IB** published a new report on JavaScript sniffers, after studying 2,440 infected websites.
- A new RAT called **RATv3.ps** may have been used by the North Korean hacking group Lazarus in their attack on banks at the end of 2018.
- In March 2019, **Group-IB** observed mass emails that contained Troldesh ransomware and purported to be from retail, wholesale, oil and gas, and construction businesses.
- An investigation into the DAVINCI BREACH leak revealed **77** restaurants where the attackers are believed to have infected POS terminals and compromised customers' bank cards.
- A botnet administrator was arrested in Novokuznetsk, Russia. The botnets comprised several thousand infected computers within and outside Russia.

Gustuff

In March 2019, Group-IB released a report on the activity of the Gustuff Android Trojan. Its targets include clients of international banks, users of mobile cryptocurrency wallets, and customers of major e-commerce businesses.

Gustuff belongs to a new generation of malware with fully automated functionality, whose aim—among other things—is to withdraw fiat money and cryptocurrencies from users' accounts. The Trojan exploits **Accessibility Service** designed for persons with disabilities.

The Trojan targets clients that use mobile applications of major banks, such as Bank of America, Bank of Scotland, J.P.Morgan, Wells Fargo, Capital One, TD Bank, PNC Bank, and cryptocurrency wallets, such as Bitcoin Wallet, BitPay, Cryptopay, Coinbase and others.

In addition, Gustuff targets users of marketplace applications, online shops, payment systems, and messengers, such as PayPal, Western Union, eBay, Walmart, Skype, WhatsApp, Gett Taxi, Revolut, and others.

Among Gustuff's victims are **32** cryptocurrency storage applications and customers of more than **100** banks, including **27** banks in the US, **16** in Poland, **10** in Austria, **9** In Germany and **8** in India.

Gustuff's infection vector is typical for Android smartphones, namely SMS messages with a link to an **APK** (Android Package), a package file format for executable Android application files.

Once downloaded to the victim's phone, Gustuff exploits Accessibility Service to work with window elements of other applications (banking, cryptocurrency, online shopping, messaging and other apps) performing actions the attackers want.

By exploiting Accessibility Service the Trojan bypasses defence mechanisms and new security policies that Google introduced in the latest Android OS versions. Gustuff knows how to disable Google Protect. The author claims that this feature works in 70% of cases.

Group-IB's Threat Intelligence system first detected Gustuff on hacker forums in April 2018. According to its developer nicknamed Bestoffer, Gustuff is an improved version of the **AndyBot** malware, which has attacked phones running Android OS since November 2017. Gustuff Bot cost $800 per month.

Group-IB's Threat Intelligence clients were promptly notified of Gustuff. Group-IB analysts continue to study the Trojan.

APT35	Microsoft took control of **99** domains used by the pro-Iranian group APT Phosphorus (also known as APT35, Charming Kitten, NewsBeef, Newscaster and Ajax Security Team) to carry out secret operations. Microsoft has been tracking the group since 2013, but experts believe it might have been active since 2011. APT35 has carried out phishing attacks against activists and journalists in the Middle East, the US, Israel, the UK, Saudi Arabia, and Iraq. Microsoft took control of domains used by Phosphorus, after filing a legal complaint in the U.S. District Court for Washington D.C. The corporation had used this approach earlier to take control of 91 websites associated with another APT called Strontium.
LUCKY ELEPHANT	The credential harvesting campaign dubbed LUCKY ELEPHANT targeted governments in South Asia, **NETSCOUT Threat Intelligence** specialists found. The hackers started the campaign in February 2019 using phishing webpages to mimic legitimate government and telecommunications sites and steal credentials. The campaign was uncovered in March 2019. The resources the hackers imitated include organisations in Pakistan, Bangladesh, Sri Lanka, the Maldives, Myanmar, and Nepal. ASERT linked LUCKY ELEPHANT to a pro-government APT from India. In particular, one of the IP addresses used in the campaign had earlier been used by DoNot Team (aka APT-C-35), a group with a long history of cyber-espionage targeting Pakistan and other countries in Asia.

Major events: espionage, sabotage, leaks

APT28

FireEye has warned that pro-Russian APTs are targeting European governments again, ahead of the upcoming European elections. The groups in question are APT28 (aka Fancy Bear, Pawn Storm, Sofacy Group, Sednit and STRONTIUM) and Sandworm Team (aka TeleBots), which **FireEye** says are targeting NATO countries. According to a report by **Symantec,** between 2017 and 2018 APT28 carried out secret cyber-espionage operations against military and government organisations in Europe and South America. **FireEye** said that the two Russia-linked APT groups had carried out phishing attacks to trick victims into revealing government information and credentials. Experts note that even though the two groups have common goals, APT28 uses zero-day exploits, while Sandworm mainly uses publicly available hacking tools.

Guri Dam

The blackout in Venezuela in March 2019, which left 80% of the country without electricity, may have been due to a cyberattack on the automatic control system at Guri Dam, said Jorge Rodriguez, Venezuela's information minister.

Back in October 2018, the Hi-Tech Crime Trends'2018 report by Group-IB warned that energy facilities would remain the primary target of sabotage-oriented hacker groups. One of the most serious threats for critical infrastructure is Industroyer or CRASHOVERRIDE, which was used in December 2016 to disrupt power network facilities in Ukraine. In 2017, the tool was thoroughly described by #ESET and its creation was linked to the #BlackEnergy group. Industroyer's specific characteristic is the ability to remotely control Remote Terminal Units (RTUs), which manage switches and circuit breakers at power grid substations. It essentially is a cyberweapon, which will allow cyberarmies to leave entire cities without electricity and water.

Major events: attacks on bank customers

Lazarus

North Korean hacker group Lazarus is using a new RAT to attack banks. At the beginning of 2019, Group-IB Threat Intelligence specialists obtained and studied a previously unknown tool used by Lazarus in **one of their most recent attacks on a bank in Asia**. Lazarus's new tool was dubbed **RATv3.ps** (Remote Access Trojan). The Trojan is believed to have been downloaded to the victims' computers in a watering hole attack. First the actors infected popular websites, which resulted in the Ratankba Trojan being installed on users' computers. Then, as a second stage, RATv3.ps was downloaded, taking full control over the victim's machine. According to Group-IB's report, watering hole attacks by the North Korean hackers were first recorded in 2016. Group-IB believes that the new **RATv3.ps** Trojan may have been used by the North Korean hackers in other attacks on banks in 2018. Its traces have been found on at least one legitimate Vietnamese website, which may have been involved in other Lazarus attacks to deliver malware to victims' computers. The Trojan Group-IB discovered is multifunctional: it is capable of exfiltrating data from the victim's computer, downloading and executing programs and commands via shell, acting as a keylogger to retrieve the victim's passwords, moving, creating and deleting files, injecting code into other processes, and screencasting.

The North Korean group Lazarus has for many years engaged in cyber-espionage against the North Korean regime's ideological enemies: US and South Korean government agencies and private corporations. In the last few years, Lazarus has attacked banks and cryptocurrencies around the world. The biggest attack was the February 2016 attempt to steal almost $1 billion from the central bank of Bangladesh through SWIFT. The hackers, however, only managed to steal $81 million. In 2017, Lazarus attacked one hundred financial organisations in 30 countries, such as the central banks of Russia, Brazil and Chile, the European Central Bank, and other organisations.

Major events: attacks on bank customers

JS-sniffers

Group-IB released the first analytical report on JavaScript Sniffers, a type of malicious code intended for capturing data entered by users on infected websites, such as bank card numbers, names, addresses, logins, passwords, etc. Hackers usually sell obtained payment data to carders on darknet forums. A significant number of users on underground forums where JS-sniffers are put up for sale or rent out are Russian-speaking.

Group-IB's analysis of **2,440** infected websites revealed that more than half of them had been attacked by **MagentoName** JS-sniffer family, whose operators exploit vulnerabilities of older versions of the **Magento CMS** (Content Management System) to inject the malicious code into the codes of websites powered by this CMS. More than 13% of infections are carried out by **WebRank** JS-sniffers family, which attacks third-party sites to inject its malicious code into the targeted websites. In addition, more than 11% of infections are carried out by JS-sniffers from the **CoffeMokko** family, whose operators use obfuscated scripts designed to steal information from payment forms of payment systems, whose field names are hardcoded into the JS-sniffer's code. Such payment systems include **PayPal, Verisign**, **Authorize.net**, **eWAY**, **Sage Pay**, **WorldPay**, **Stripe**, **USAePay**, and others. Many JS-sniffer families use unique options for each payment system, which requires modifying and testing the script before each infection.

The majority of the identified JS-sniffers were set up to steal information from different types of payment forms of website management systems such **as Magento, OpenCart, Shopify, WooCommerce,** and **WordPress**. Such JS-sniffer families include **PreMage**, **MagentoName**, **FakeCDN**, **Qoogle**, **GetBilling**, and **PostEval**. Other JS-Sniffers are universal and can be integrated into the code of any website, regardless of the systems used (G-Analytics, WebRank).

The threat posed by JS-sniffers had long been under the radar of malware analysts, who deemed it insignificant and unworthy of in-depth research. The attitude to this threat, however, should change as there are cases, such as **380,000** victims of a JS-sniffer that infected the **British Airways** website and mobile app, the compromise of **Ticketmaster** users' payment data, and the recent incident involving the UK website of the international sporting goods giant **FILA**, which could have led to the theft of payment details of at least 5,600 customers.

Major events: breach and leaks

DAVINCI BREACH

The first set of dumps dubbed DAVINCI BREACH surfaced on Joker's Stash, an underground marketplace, whose owner says the full database contains **2.1** million cards. As of 25 March 2019, **28** databases from DAVINCI BREACH have been published with **473,840** cards available. Group-IB specialists established that the compromised cards had been used in the US restaurant chains **Buca di Beppo Italian Restaurant, Earl of Sandwich and Planet Hollywood**, which are all part of **Earl Enterprises**, their parent company. The attackers are believed to have infected POS terminals in **77** restaurants. The fact that all of the restaurant chains are serviced by **Datum Technologies** could suggest that the initial access to the terminals was gained after compromising Datum Technologies's network. With access to **Datum Technologies** the attackers were able to infect POS terminals with malware that intercepts magnetic stripe data from infected devices' RAM. Some of the cards may have been cashed out by the threat actors, while others may have been sold on Joker's Stash.

THack3forU

It was found that medical data on ambulance patients in several towns in the Moscow Region, Russia had been publicly available. The database contained names, addresses, telephone numbers, and information about the patients' health. It was essentially publically available on **MongoDB** servers (database management system) and did not require authorisation or any other security settings. The distribution of the database has been attributed to the Ukrainian hacktivists THack3forU (as they call themselves). The danger lies in the fact that if such databases are published, the data can be exploited by threat actors. Medical data is one of the most sensitive kind of information, and the fact that this case involved a system where all of the data was publically available and stored outside Russia shows that neither the system's development nor its acceptance complied with the Russian law. This particular case clearly violated a number of laws, such as the Federal Act 152 "On personal data", Federal Service for Technical and Export Control Order No. 21, Government Decision 1119, Government Decision 687 and methodological recommendations for medical centres.

Major events: ransomware

Troldesh

In March 2019, Group-IB reported about new mass emails with Troldesh ransomware (aka Shade, XTBL, Trojan.Encoder.858). In addition to encrypting files on an infected device and demanding a ransom, Troldesh mines cryptocurrency. The new technique of delivering it through phishing emails was detected by the experts on 1 November 2018 (it was disguised as coming from a major bank), then in December (also from banks). In January, however, it was masked as coming from a retail player. Troldesh is usually disguised as coming from banks, but this time its authors decided to masquerade as companies from various industries, such as retail, wholesale, oil and gas, and construction. At the peak of the phishing attack, we saw up to 2,000 such emails per day. Troldesh has been the most popular ransomware recently. Group-IB's Incident Response team traced it in at least seven incidents in 2018.

Major events: tools and services

Arkei

In February 2019, a **Lolzteam** forum user with the nickname foxovsky made a post about stopping supporting Arkei stealer and gave public access to its builder and admin panel. Arkei was first detected in December 2017 on **Bhf**, an underground forum. The price ranged from 2,000 to 5,000 roubles ($31-78). Arkei is designed to collect passwords, cookies, bank card data, digital wallet data (Bitcoin, Ethereum), Chromium and Firefox-based autofilled web forms, and files of any format from the desktop. It is also capable of extracting information about the user's computer and installed software. Arkei's specific characteristic is that it combines stealer and loader functionality, and can also bypass various anti-viruses.

The reason the Arkei builder was published could be its developer's unwillingness to continue to support the stealer due to more promising projects, which as foxovsky noted, borrowed parts of Arkei's source code. In addition, many users who had bought the private version of the malware earlier were disappointed with it. They believe the malware contains a backdoor and collects data from the builder's owner. This could mean that one of the reasons for publishing the builder was its mass distribution in order to collect personal information about Arkei's users.

Baldr

A stealer called Baldr was put up for sale on underground forums. The malware can collect passwords from browsers, cryptocurrency wallets, messenger data, FTP clients, and other programs. The stealer has loader functionality, which enables it to download other malicious programs to infected devices. The stealer's developer is a user with the nickname **LordOdin**, while its seller is a user nicknamed overdot, who sold several malicious programs, including Arkei, before.

Major events: tools and services

Exobot Compact

In March 2019, an underground forum user put up for sale Exobot Compact, a new version of the Android banking Trojan Exobot. The malware can send and delete SMS messages, display fake web pages of banking applications, send USSD requests, and block infected devices. We should note that in May 2018 the source code of Exobot 2.0 was published. According to the author, the third version was completely rewritten and optimized as compared to the second one. The Trojan on sale comes with an admin panel and an Android loader built in the panel. The loader downloads other malicious APK files. Additional services provided by the author include encryption and clean-up of malware files to prevent AV detection, over 150 ready-made web injects, and development and implementation of customized web fakes for customers' applications. The program costs **$1,500** per month. The author does not allow the Android Trojan to be used in the US and the CIS.

Legal cases and arrests

Cybercrime -as-a-service

The Russian police together with Group-IB experts arrested a botnet administrator in Novokuznetsk, Kemerovo Region, Russia. The botnet comprised several thousand infected computers within and outside Russia. The detainee was a mercenary, who offered cybercriminal groups cybercrime-as-a-service. The detainee deployed, tested and serviced Trojans' admin panels on rented servers. They also stole accounts (logins and passwords of email clients and browsers) to sell them on underground forums.

The investigation was launched after a major incident in the spring of 2018, when the Novokuznetsk hacker infected about 1,000 personal computers within and outside Russia using the Pony Formgrabber Trojan designed for account theft. The attacker managed to gain access to their victims' email accounts and correspondence. The botnet existed for a year between the autumn of 2017 and August 2018. During that period, it stole personal data and accounts from infected machines.

The police believe that the detainee offered their administrator services on underground forums and had occasional orders from cybercriminals to set up servers to manage botnets. Their potential affiliation with a particular hacking group and side jobs with other groups is also being considered.

As part of investigation Group-IB experts tracked down an unemployed 25-year-old resident of Novokuznetsk. The detainee specialised in RATs (Remote Access Trojans), namely **Pony, SmokeBot, BetaBot, Novobot, njRAT, Neutrino, DiamondFox, Tresure Hunter RAMScraper** (for POS terminals), and others, which enabled the hacker to gain full access to infected computers. The detainee has been charged with an offence under part 1 of article 273 of the Russian Criminal Code (Creation, use, and distribution of malicious computer software). They fully confessed their guilt and the investigation is under way.

Forecasts and warnings

- After testing their new tool called **RATv3.ps** in a recent attack on an Asian bank, hackers from the Lazarus group are likely to use it in attacks on financial organisations and cryptocurrency exchanges around the world.
- Casual attitude of antivirus analysts, banks, and e-commerce businesses to JS Sniffers, their ease of use, and their low barrier to entry in criminal activity may cause a spike in the number of infected websites and victims, and increase the amount of compromised data.
- Troldesh, one of the most popular ransomware families, will be distributed not only disguised as coming from banks, but also masqueraded as banks' contractors and other companies from various industries, such as retail, wholesale, oil and gas, and construction.
- Open access to Arkei stealer may not only cause its widespread use, but also result in Arkei users having their personal data collected. It has been suggested that the malware contains a backdoor and collects its owner's personal data.

If you wish to receive more detailed information about a specific incident, threat or criminal group:

Please contact us.

We can conduct investigations to give you the maximum intelligence on the threats targeting your organization.

+1 917 809 47 41
+7 495 984 33 64
intelligence@group-ib.com